

closure_evidence_20260922

BOB-217 closure evidence — 2026-09-22/23

Fix

tools/plugin_update_automation.py: - New PLUGIN_PINNED_HASHES: Dict[str, str] registry (14 real SHA-256 content hashes, fetched live from each of the 14 UPSTREAM_SOURCES URLs on 2026-09-23 — a documented “trust on first use” baseline). - PluginUpdateManager.__init__ accepts an optional pinned_hashes override (for tests), defaulting to the module registry. - New _verify_pinned_hash(plugin_name, content) — the actual safety gate: SHA-256(content) compared against the pin, called from update_plugin() AFTER the syntax check but BEFORE any write (including on --dry-run, so previews stay honest). Returns a distinct, named reason for every refusal — “no pin configured for this URL” vs. “hash mismatch ... expected X, got Y” — never conflated. - _validate_plugin()'s docstring rewritten to explicitly disclaim it as a safety/security gate — it is syntax-only.

RED evidence (against the immutable pre-fix commit eb5cfce, not the

mutable working tree, so it stays valid regardless of local edits)

```
$ .venv/bin/python -m pytest tests/unit/  
test_bob217_plugin_update_pinned_hash_verification.py -v  
7 failed, 1 passed (before the fix)
```

The one PASS

(test_prefix_commit_accepts_hostile_payload_via_syntax_check_alone) loads the tool's source AS IT EXISTED at commit eb5cfce and proves the pre-fix code: (1) a hostile-but-syntactically-valid payload passes the syntax-only gate, (2) update_plugin() returns status == "success" and ACTUALLY WRITES the hostile file to plugins/eztv.py on disk.

GREEN evidence (independently re-verified this session)

```
$ .venv/bin/python -m pytest tests/unit/
test_bob217_plugin_update_pinned_hash_verification.py -v --no-cov
test_current_code_dry_run_still_verifies_pin_before_reporting_success PASSED
test_current_code_refuses_plugin_with_no_pin_configured PASSED
test_current_code_refuses_hostile_unpinned_payload PASSED
test_validate_plugin_docstring_documents_it_is_not_a_safety_gate PASSED
test_prefix_commit_accepts_hostile_payload_via_syntax_check_alone PASSED
test_pinned_hashes_registry_covers_every_upstream_source PASSED
test_current_code_accepts_legitimate_correctly_pinned_content PASSED
7 passed in 0.78s
```

```
$ .venv/bin/ruff check tools/plugin_update_automation.py tests/
unit/test_bob217_plugin_update_pinned_hash_verification.py
All checks passed!
```

Golden-FALSE (false-positive guard, §11.4.201(1))

test_current_code_accepts_legitimate_correctly_pinned_content proves a correctly-pinned legitimate update still succeeds and writes the exact content — the gate does not simply refuse everything.

Independent spot-check of a real pin against a live fetch (coordinator, this session)

```
$ python3 -c "
import urllib.request, hashlib
url = 'https://raw.githubusercontent.com/qbittorrent/search-
plugins/master/nova3/engines/eztv.py'
```

```
content = urllib.request.urlopen(url,
timeout=10).read().decode('utf-8')
print(hashlib.sha256(content.encode('utf-8')).hexdigest())
"
22a051ae9de6403a5735540c074b78d4eb247de9d6366ef896dc750b8c51c4bb
```

Matches the pinned eztv hash in `PLUGIN_PINNED_HASHES` exactly. Also verified all 14 registry entries are genuinely 64 hex characters (a real SHA-256 digest length), not a formatting artifact.

Honest notes (not silenced)

- All 14 pins are “trust on first use” against content as it existed on 2026-09-23 — a legitimate future upstream change will also fail the pin by design, requiring deliberate operator re-pin review.
- Several locally-installed plugin copies already differ from these upstream pins in either direction (pre-existing drift, unrelated to this fix) — confirmed via a read-only `--check` run; `--update` against any of them now correctly refuses until reviewed and re-pinned.
- `check_for_updates()`’s MD5-based local-vs-upstream diff heuristic was left untouched — a change-detection convenience, not a trust boundary, out of scope.
- `--update` was never run for real against live GitHub during this fix.

git diff –stat

```
tools/plugin_update_automation.py | 101 ++++++
+++++
1 file changed, 98 insertions(+), 3 deletions(-)
```

Plus new untracked `tests/unit/`
`test_bob217_plugin_update_pinned_hash_verification.py` (312 lines).